informe de vulnerabilidades de RSA learn

Sitio: http://localhost:3000

Generado a lun, 12 oct 2026 16:02:27

ZAP Versión: 2.17.0

ZAP by Checkmarx

Sumario de Alertas

Nivel de riesgo	Número de Alertas
Alto	0
Medio	4
Bajo	2
Informativo	0

Insights

Level	Razón	Site	Descripción	Statistic
Información	Informativo	http://localhost:3000	Percentage of responses with status code 2xx	11 %
Información	Informativo	http://localhost:3000	Percentage of responses with status code 3xx	70 %
Información	Informativo	http://localhost:3000	Percentage of responses with status code 4xx	18 %
Información	Informativo	http://localhost:3000	Percentage of endpoints with content type text/css	42 %
Información	Informativo	http://localhost:3000	Percentage of endpoints with content type text /html	57 %
Información	Informativo		Percentage of	100 %

		http://localhost:3000	endpoints with method GET	
Información	Informativo	http://localhost:3000	Count of total endpoints	7

Alertas

Nombre	Nivel de riesgo	Número de Instancias
CSP: Failure to Define Directive with No Fallback	Medio	2
Cabecera Content Security Policy (CSP) no configurada	Medio	3
Falta atributo de integridad de recursos secundarios	Medio	1
Falta de cabecera Anti-Clickjacking	Medio	3
El servidor divulga información mediante un campo(s) de encabezado de respuesta HTTP ""X-Powered-By""	Bajo	Systemic
Falta encabezado X-Content-Type-Options	Bajo	Systemic

Detalles de la Alerta

Medio	CSP: Failure to Define Directive with No Fallback
Descripción	The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.
URL	http://localhost:3000/robots.txt
Nombre del Nodo	http://localhost:3000/robots.txt
Método	GET
Ataque	
Evidencia	default-src 'none'
Otra información	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
URL	http://localhost:3000/sitemap.xml
Nombre del Nodo	http://localhost:3000/sitemap.xml
Método	GET
Ataque	
Evidencia	default-src 'none'
Otra información	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
Instancia	2
Solución	Asegúrese de que su servidor web, servidor de aplicación, balanceador de carga, etc. está configurado apropiadamente para establecer la cabecera de Política de Seguridad de Contenido.
	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy

Referencia	https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medio	**Cabecera Content Security Policy (CSP) no configurada**
Descripción	La Política de seguridad de contenido (CSP) es una capa adicional de seguridad que ayuda a detectar y mitigar ciertos tipos de ataques, incluidos Cross Site Scripting (XSS) y ataques de inyección de datos. Estos ataques se utilizan para todo, desde el robo de datos hasta la desfiguración del sitio o la distribución de malware. CSP proporciona un conjunto de encabezados HTTP estándar que permiten a los propietarios de sitios web declarar fuentes de contenido aprobadas que los navegadores deberían poder cargar en esa página; los tipos cubiertos son JavaScript, CSS, marcos HTML, fuentes, imágenes y objetos incrustados como applets de Java, ActiveX, archivos de audio y video.
URL	http://localhost:3000
Nombre del Nodo	http://localhost:3000
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:3000/login/login.html
Nombre del Nodo	http://localhost:3000/login/login.html
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:3000/registro/registro.html
Nombre del Nodo	http://localhost:3000/registro/registro.html
Método	GET
Ataque	
Evidencia	
Otra información	
Instancia	3
Solución	Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. esté configurado para establecer la cabecera Content-Security-Policy.
Referencia	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/

CWE Id	693
WASC Id	15
Plugin Id	10038

Medio	Falta atributo de integridad de recursos secundarios
Descripción	Falta el atributo de integridad en una etiqueta de script o enlace servida por un servidor externo. La etiqueta de integridad evita que un atacante que haya obtenido acceso a este servidor inyecte un contenido malicioso.
URL	http://localhost:3000
Nombre del Nodo	http://localhost:3000
Método	GET
Ataque	
Evidencia	<link href="https://fonts.googleapis.com/css2?family=Keania+One&display=swap" rel="stylesheet">
Otra información	
Instancia	1
Solución	Proporcionar un atributo de integridad válido a la etiqueta.
Referencia	https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003

Medio	Falta de cabecera Anti-Clickjacking
Descripción	La respuesta no protege contra ataques de "ClickJacking". Debes incluir Content-Security-Policy con la directiva "frame-ancestors" o X-Frame-Options.
URL	http://localhost:3000
Nombre del Nodo	http://localhost:3000
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:3000/login/login.html
Nombre del Nodo	http://localhost:3000/login/login.html
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:3000/registro/registro.html
Nombre del Nodo	http://localhost:3000/registro/registro.html
Método	GET

Ataque	
Evidencia	
Otra información	
Instancia	3
Solución	Los navegadores web modernos admiten las cabeceras HTTP Content-Security-Policy y X-Frame-Options. Asegúrese de que una de ellas está configurada en todas las páginas web devueltas por su sitio/aplicación. Si espera que la página esté enmarcada solo por páginas en su servidor (por ejemplo, si forma parte de un FRAMESET), utilice SAMEORIGIN; de lo contrario, si no espera que la página esté enmarcada, utilice DENY. Alternativamente, considere implementar la directiva "frame-ancestors" de la Política de Seguridad de Contenidos.
Referencia	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Bajo	**El servidor divulga información mediante un campo(s) de encabezado de respuesta HTTP ""X-Powered-By""**
Descripción	El servidor de la web/aplicación está divulgando información mediante uno o más encabezados de respuesta HTTP ""X-Powered-By"". El acceso a tal información podría facilitarle a los atacantes la identificación de otros marcos/componentes de los que su aplicación web depende y las vulnerabilidades a las que pueden estar sujetos tales componentes.
URL	http://localhost:3000/css/style.css
Nombre del Nodo	http://localhost:3000/css/style.css
Método	GET
Ataque	
Evidencia	X-Powered-By: Express
Otra información	
URL	http://localhost:3000/login/estilos.css
Nombre del Nodo	http://localhost:3000/login/estilos.css
Método	GET
Ataque	
Evidencia	X-Powered-By: Express
Otra información	
URL	http://localhost:3000/registro/estilo.css
Nombre del Nodo	http://localhost:3000/registro/estilo.css
Método	GET
Ataque	
Evidencia	X-Powered-By: Express
Otra información	

URL	http://localhost:3000/robots.txt
Nombre del Nodo	http://localhost:3000/robots.txt
Método	GET
Ataque	
Evidencia	X-Powered-By: Express
Otra información	
URL	http://localhost:3000/sitemap.xml
Nombre del Nodo	http://localhost:3000/sitemap.xml
Método	GET
Ataque	
Evidencia	X-Powered-By: Express
Otra información	
Instancia	Systemic
Solución	Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. está configurado para suprimir las cabeceras "X-Powered-By".
Referencia	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10037

Bajo	**Falta encabezado X-Content-Type-Options**
Descripción	La cabecera Anti-MIME-Sniffing X-Content-Type-Options no se ha establecido en 'nosniff'. Esto permite que las versiones anteriores de Internet Explorer y Chrome realicen MIME-sniffing en el cuerpo de la respuesta, lo que puede provocar que el cuerpo dé la respuesta se interprete y se muestre como un tipo de contenido distinto del tipo de contenido declarado. Las versiones actuales (principios de 2014) y heredadas de Firefox utilizarán el tipo de contenido declarado (si se establece uno), en lugar de realizar MIME-sniffing.
URL	http://localhost:3000
Nombre del Nodo	http://localhost:3000
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:3000/css/style.css
Nombre del Nodo	http://localhost:3000/css/style.css

Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:3000/login/estilos.css
Nombre del Nodo	http://localhost:3000/login/estilos.css
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:3000/registro/estilo.css
Nombre del Nodo	http://localhost:3000/registro/estilo.css
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:3000/registro/registro.html
Nombre del Nodo	http://localhost:3000/registro/registro.html
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
Instancia	Systemic
	Asegúrese de que la aplicación/servidor web establece el encabezado Content-Type adecuadamente, y que establece el encabezado X-Content-Type-Options a 'nosniff' para todas las páginas web.

Solución	Si es posible, asegúrese de que el usuario final utiliza un navegador web moderno y compatible con los estándares que no realiza MIME-sniffing en absoluto, o que puede ser dirigido por la aplicación web/servidor web para que no realice MIME-sniffing.
Referencia	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021